There are a few ways to communicate identity in a capability-based system:

- You can associate a username and other identity claims with each capability token. The permissions in the token are still what grants access, but the token additionally authenticates identity claims about the user that can be used for audit logging or additional access checks. The major downside of this approach is that sharing a capability URI lets the recipient impersonate you whenever they make calls to the API using that capability. Nevertheless, this approach can be useful when generating short-lived capabilities that are only intended for a single user. The link sent in a password reset email can be seen as this kind of capability URI as it provides a limited-time capability to reset the password tied to one user’s account.
- You could use a traditional authentication mechanism such as a session cookie to identify the user in addition to requiring a capability token, as shown in figure 9.5. The cookie would no longer be used to authorize API calls but would instead be used to identify the user for audit logging or for additional checks. Because the cookie is no longer used for access control it is less sensitive and so can be a long-lived persistent cookie, reducing the need for the user to frequently log in.